

CampusSetu — Security Assessment Report

Comprehensive Vulnerability Audit (Node.js/Express Backend & Flutter Mobile/Web)

Audit Date: October 04, 2026
Mode: Defensive Read-Only Inspection
Target: Production/Staging Codebase
Auditor: Antigravity Security Reviewer

23
TOTAL ISSUES

2
CRITICAL

8
HIGH

9
MEDIUM

4
LOW / INFO

1. Master Findings Table (Ordered by Risk Priority)

Columns: ID | Severity | File:Line | Problem | Suggested Fix

ID	Severity	File:line	Problem Description	Suggested Fix
SEC-A01	CRITICAL	env/dev.env.json env/admin.env.json env/user.env.json	Environment configuration files committed directly into Git repository history (commits 21b9d399 & 64056357).	Run <code>git rm --cached env/*.json</code> , purge git history with <code>git-filter-repo</code> , add <code>env/*.json</code> to <code>.gitignore</code> .
SEC-E01	CRITICAL	backend/src/routes/enterprise.routes.js:7	Broken Access Control / Missing Role Check: Enterprise POS routes use only <code>requireAuth</code> ; <code>requireEnterprise</code> is completely omitted. Any regular student can access restaurant bills, food menu, staff, and <code>udhaar</code> .	Mount <code>router.use(requireAuth, requireEnterprise)</code> so standard student tokens are rejected with HTTP 403.
SEC-A02	HIGH	.gitignore:50	Incomplete <code>.gitignore</code> rules: only root <code>.env</code> is excluded; ignores <code>backend/.env*</code> , <code>*.pem</code> , <code>*.key</code> , and <code>env/*.json</code> . No <code>backend/.gitignore</code> exists.	Update root <code>.gitignore</code> with <code>**/.env*</code> , <code>env/*.json</code> , <code>*.pem</code> , <code>*.key</code> , and create a dedicated <code>backend/.gitignore</code> .
SEC-M01	HIGH	backend/package.json	20 npm vulnerabilities (9 High, 11 Moderate), including <code>@grpc/grpc-js</code> (auth certificate bypass), <code>node-forge</code> (RSA signature bypass), <code>joi</code> (ReDoS), and <code>braces</code> (CPU DoS).	Execute <code>npm audit fix</code> ; update <code>firebase-admin</code> , <code>joi</code> , and nested dependencies to patched releases.
SEC-E02	HIGH	enterprise.routes.js:40 admin.routes.js:9	Authorization Bypass: <code>/api/v1/enterprise/redeem</code> lacks <code>requireEnterprise</code> while <code>/admin/enterprise/redeem</code> requires it. Regular students can redeem other students' coupon codes.	Apply <code>requireEnterprise</code> middleware to <code>/api/v1/enterprise/redeem</code> to restrict redemptions to authorized merchants.
SEC-E03	HIGH	backend/src/controllers/enterprise.controller.js:439	IDOR in Multi-Tenant Store Data: In <code>addStaffAdvance</code> , client-supplied <code>staff_id</code> is inserted without verifying that the employee belongs to the requester's <code>store_id</code> .	Verify employee ownership prior to advance recording: <code>SELECT id FROM enterprise_staff WHERE id = \$1 AND store_id = \$2</code> .
SEC-F01	HIGH	backend/src/middleware/validate.js:21	Widespread Missing Schema Validation: Only 3 routes use <code>Joi</code> validation. Over 30 endpoints accept raw payloads without type, length, or boundary validation.	Define strict <code>Joi</code> or <code>Zod</code> schemas for all mutating endpoints (<code>Jobs</code> , <code>Events</code> , <code>Rides</code> , <code>Bills</code> , <code>Flatmates</code> , <code>Staff</code> , etc.).
SEC-F02	HIGH	backend/src/controllers/quiz.controller.js:28	Stored XSS via File Upload: Image upload filter checks	Enforce strict mime whitelist (<code>jpeg</code> , <code>png</code> , <code>webp</code>); reject <code>SVG</code> and execute

ID	Severity	File:line	Problem Description	Suggested Fix
			file.mimetype.startsWith('image/'), allowing image/svg+xml containing malicious JavaScript <script> tags.	magic byte verification.
SEC-CD01	HIGH	backend/src/middleware/auth.js:80	Delayed Token Revocation Window: Decoded Firebase ID tokens are cached in Redis/Memory for 5 minutes. Banned or revoked users retain API access until cache expiry.	Reduce token cache TTL to 60s or bypass cache on critical/administrative operations to respect instant revocation.
SEC-G01	HIGH	backend/src/index.js:50-55	Overly Permissive CORS Policy: origin: '*' is enabled across all HTTP methods. Any arbitrary web domain can send cross-origin requests to API endpoints.	Whitelist specific production origin domains (e.g. campussetu-user.pages.dev) and block wildcard access in production.
SEC-H01	HIGH	backend/src/routes/alarmWallpaper.routes.js:16-35	Unrestricted File Upload: application/octet-stream is included in allowed mimetypes. Any executable or binary payload up to 50MB can be uploaded as .riv.	Remove generic octet-stream; validate Rive binary headers (magic byte RIVE) on uploaded file buffers.

Master Findings Table (Continued: Medium & Low Severity)

Part 2 of 2

ID	Severity	File:line	Problem Description	Suggested Fix
SEC-A03	MEDIUM	backend/node_modules/ (Git commit 21b9d399)	backend/node_modules/ committed in historical commit 21b9d399, causing potential repository footprint and metadata tracking issues.	Purge node_modules from git index and commit history using git filter-branch or BFG.
SEC-M02	MEDIUM	pubspec.yaml	Outdated & Discontinued Flutter Packages: 4 discontinued packages identified (flutter_secure_storage_macos, js, build_resolvers, build_runner_core); 82 packages constrained to legacy versions.	Replace discontinued dependencies; execute flutter pub upgrade -- major-versions in a test branch.
SEC-E04	MEDIUM	backend/src/routes/ quiz.routes.js:19	POST /quiz/faculty/register is unauthenticated and lacks rate limiting, exposing Firebase and PostgreSQL to registration flooding.	Apply strict rate limiting (e.g. 5 requests per 15 minutes per IP) to the faculty registration endpoint.
SEC-E05	MEDIUM	backend/src/routes/ jobs.routes.js:9	POST /jobs allows any authenticated student to submit job posts without input validation or recruitment authorization check.	Restrict job posting to verified recruiters/admins or implement strict schema checks and captchas.
SEC-F03	MEDIUM	backend/src/controllers/ products.controller.js:77	PATCH /products/:id/status accepts any arbitrary string in status without checking against allowed values.	Validate against whitelist: ['active', 'sold', 'removed'].includes(status).
SEC-CD02	MEDIUM	backend/src/controllers/ passwordReset.controller.js:16	Weak OTP Entropy: Password reset OTP is 4 digits from digits 1-9 (only ~6,561 combinations). OWASP recommends minimum 6 numeric digits (1,000,000 combinations).	Increase OTP length to 6 digits: randomInt(100000, 1000000) with digits 0-9.
SEC-CD03	MEDIUM	backend/src/socket/ quiz.socket.js:49	Authentication Token in URL Query: WebSocket upgrade reads token from ?token=..., causing token exposure in proxy/server logs.	Use ticket-based one-time code exchange or pass token in Sec- WebSocket-Protocol or initial message.
SEC-G02	MEDIUM	backend/src/index.js:595	Missing Centralized Error Handler: Express lacks global error handling middleware. Controllers return err.message directly, leaking internal DB queries and table names.	Add app.use((err, req, res, next) => ...) returning generic messages in production while logging details securely.
SEC-H02	MEDIUM	backend/src/routes/ notes.routes.js:18	File upload routes depend purely on client-supplied file.mimetype header without server-side magic byte buffer verification.	Integrate file-type library to inspect file header signatures on disk or buffer before accepting files.
SEC-L01	MEDIUM	lib/firebase_options.dart:2 7, 39	Firebase Web and Android API keys are hardcoded in Flutter client source code.	Enforce strict API Key Restrictions in Google Cloud Console (bind to Android package name + SHA-1 fingerprint).
SEC-L02	MEDIUM	android/app/src/main/ AndroidManifest.xml:5	REQUEST_INSTALL_PACKAGES used to download and install raw APK from GitHub releases without	Verify downloaded APK SHA-256 signature prior to prompting

ID	Severity	File:line	Problem Description	Suggested Fix
			cryptographic SHA-256 hash validation.	installation, or transition to Google Play In-App Updates.
SEC-CD04	LOW	backend/src/routes/users.routes.js	No explicit backend POST /users/logout route to immediately invalidate cached tokens in Redis on user sign-out.	Add server-side logout route that purges auth:token:<hash> from Redis on sign-out.
SEC-I01	LOW	backend/src/index.js:56	Morgan logger (morgan('dev')) writes full request URLs including query strings to stdout.	Redact query parameters from HTTP access logs in production environments.
SEC-L03	LOW	lib/core/services/auth_service.dart:75	Device installation ID stored in plain SharedPreferences rather than FlutterSecureStorage.	Migrate sensitive local identifiers to Keychain / Keystore via FlutterSecureStorage.
SEC-K01	INFO	backend/src/ & lib/	AI Endpoints: No external LLM (Gemini/OpenAI) endpoints currently active.	When adding AI features, ensure server-side API key containment, PII redaction, and prompt rate limiting.

2. Domain-by-Domain Architectural Assessment

Areas A through L

🔑 Area A: Secrets Management, Git Tracking & Commit History

- **Git Leakage:** `env/dev.env.json`, `env/admin.env.json`, and `env/user.env.json` are tracked under Git in commits 21b9d399 and 64056357. While they contain local endpoint URLs, committing environment files sets a dangerous pattern and may expose backend staging endpoints.
- **.gitignore Deficiency:** Root `.gitignore` only matches exact `.env` at root level. Any subfolder env file (such as `backend/.env` or `.env.production`) would be tracked if created.
- **Firebase Service Account:** `backend/src/config/firebase.js` relies on `FIREBASE_SERVICE_ACCOUNT` environment variable with fallback to `firebase-service-account.json` (which is properly gitignored).

📦 Area M: Dependency Security & Outdated Modules

- **Node.js (npm audit):** 20 total vulnerabilities (9 High, 11 Moderate). High severity vulnerabilities in `@grpc/grpc-js` and `node-forge` allow potential authentication bypass and signature verification flaws. `Joi` has a known ReDoS vulnerability in `isoDate`.
- **Flutter / Dart:** 4 discontinued packages detected (including `flutter_secure_storage_macos` and `js`). 82 packages have newer resolvable versions available.

🔑 Area E: Route Authorization, Role Checks & IDOR Multi-Tenancy

- **Enterprise POS Route Exposure (Critical):** In `enterprise.routes.js`, all routes are mounted with `router.use(requireAuth)` without `requireEnterprise`. Standard student accounts can make REST calls to read and write restaurant sales, bills, food items, and staff records.
- **Redemption Bypass (High):** Deal redemption via `/api/v1/enterprise/redeem` lacks enterprise verification, allowing unauthorized deal code redemptions.
- **Staff Advance IDOR (High):** In `enterprise.controller.js:439`, advances can be recorded against any `staff_id` without validating that the staff belongs to the active store.
- **Owner Verification in Social Modules (Compliant):** Posts (`posts.controller.js:197`), Flatmates (`flatmates.controller.js:128`), and Profile updates (`users.controller.js:217`) correctly enforce ownership checks via `WHERE author_id = $1` or `WHERE firebase_uid = $1`.

🔑 Area F: Input Validation, SQL Injection, XSS & SSRF

- **SQL Injection (Clean):** Queries across all controllers consistently use parameterized placeholders (`$1`, `$2`, ...) with `pg`. Dynamic filter queries properly append to parameter arrays.
- **Stored XSS via SVG (High):** `quiz.controller.js:28` allows `image/svg+xml`, which can execute embedded JavaScript in the browser context when viewed directly from `/uploads/quiz/`.
- **SSRF (Clean):** Only one outbound HTTP request exists (in `passwordReset.controller.js` to `https://api.resend.com/emails`) targeting a fixed, non-user-controlled URL.
- **Missing Schemas:** 30+ endpoints accept unvalidated request bodies, relying on manual ad-hoc checks.

Area C/D: Password Security, JWT, Refresh Tokens & WebSocket Handshake

- **Password Hashing:** Handled securely by Firebase Authentication; password reset OTPs are hashed using bcrypt with 10 salt rounds.
- **OTP Entropy:** Reset OTP is only 4 digits (approx 6,561 combinations). Must be upgraded to 6 digits.
- **Token in URL:** WebSocket upgrades (`quiz.socket.js:49`) pass JWT in query parameter (`?token=...`), exposing tokens to proxy access logs.
- **Token Revocation Window:** In-memory and Redis token caching (5 minutes) causes a window where revoked tokens remain accepted.

Area G: CORS, Helmet, HTTP Security Headers & Error Handling

- **CORS:** Permissive wildcard (`origin: '*'`) allows any origin to send cross-origin requests. Must be restricted to trusted domains in production.
- **Helmet:** Enabled with cross-origin policies; `X-Powered-By` is removed by default.
- **Error Disclosure:** Controllers reflect `err.message` back to clients in 500 responses, exposing internal database details.

Area H: File Upload Security

- **Wallpaper Upload:** `application/octet-stream` is whitelisted, allowing any binary to be uploaded as `.riv`.
- **MIME Sniffing:** Uploaders rely on client-provided `file.mimetype` instead of inspecting file magic bytes.

Area L: Flutter Client Security & Update Integrity

- **API Keys:** Firebase keys are in `firebase_options.dart`; must be locked down via Google Cloud Console restrictions.
- **In-App Updates:** Self-updating via GitHub releases downloads APKs directly without checking SHA-256 integrity checksums.